

Date of current version 03 November 2025.

Digital Object Identifier

Toward a Common Understanding of Cryptographic Agility – A Systematic Review

CHRISTIAN NÄTHER¹, DANIEL HERZINGER², JAN-PHILIPP STEGHÖFER¹, (Member, IEEE),
STEFAN-LUKAS GAZDAG², EDUARD HIRSCH³, AND DANIEL LOEBENBERGER⁴

¹XITASO GmbH, Augsburg, 86153 Germany

²genua GmbH, Kirchheim, 85551 Germany

³Technical University of Applied Sciences Amberg-Weiden, Amberg, 92224 Germany

⁴Fraunhofer AISEC, Garching, 85748 Germany

Corresponding author: Christian Näther (e-mail: christian.naether@xitaso.com)

The work was funded by the German Federal Ministry of Education and Research.

ABSTRACT Cryptographic agility has become a recurring theme in both academic and industrial discussions, driven by the need to adapt cryptography under evolving threats and disruptive changes such as post-quantum cryptography. Yet despite its rising importance, the concept itself remains inconsistently defined and often conflated with related notions, limiting its value for research and practice.

This paper offers the first systematic study of cryptographic agility by providing the following research contributions: First, we review existing definitions and classify their shared characteristics across 84 screened sources, of which 48 are included in our analysis (24 peer-reviewed, 24 gray literature), thereby exposing the lack of consensus within the current literature (RQ1). Second, we synthesize these findings into a literature-based definition that unifies the most significant aspects identified in the literature (RQ2). Third, we refine this foundation into a general, context-independent definition that isolates agility as the property of changeability of cryptographic entities (RQ3). Fourth, we extend the concept by introducing a layer model with four overarching domains—conceptual, software, hardware, and organization—and by clarifying its relation to neighboring concepts such as cryptographic versatility and interoperability (RQ4).

We demonstrate the applicability of our results by analyzing the three real-world exemplars OpenSSL, NGINX, and GitLab CI/CD. Finally, we discuss broader implications, including trade-offs with complexity, its assessment across contexts, and the role of agility in cryptographic migration. Our work establishes a unified terminology and conceptual foundation for cryptographic agility, enabling consistent reasoning and guiding both research and practice in designing systems that can adapt securely and sustainably.

INDEX TERMS Cryptographic Agility, Crypto-Agility, Cryptographic Interoperability, Cryptography

I. INTRODUCTION

Cryptography is an integral part of our digital world. It ensures information security across diverse domains, from encryption protocols securing web traffic and cloud storage authentication [49] to technologies such as blockchain [50]. Almost every guarantee of trust in the IT landscape relies on cryptography [51].

In the near future, the landscape of cryptography is about to change with increasing pace. Advances in quantum computing [52] have the potential to weaken or even break essential cryptographic algorithms by solving the underlying mathematical problems significantly faster than classical computers [53,

54]. The main response is the migration to post-quantum cryptography (PQC) [55, 56]. The urgency of this transition made PQC migration a role model of applied cryptography. Beyond the PQC migration, attack vectors such as side-channel attacks [57] and advancements in cryptanalysis [58] continually challenge the security of established cryptographic systems. The deprecation of TLS 1.0 and TLS 1.1 provides a concrete illustration: although both versions were widely recognized as insecure, their removal required years of coordinated effort across widely deployed systems before it could be enforced [59]. Governmental agencies and institutions have emphasized the importance of cryptographic agility for several years and consider it a significant aspect for future recommendations and requirements [54, 60–63].

This work has been submitted to the IEEE for possible publication. Copyright may be transferred without notice, after which this version may no longer be accessible.

Historical transitions also illustrate why cryptographic agility is essential, demonstrating both progress and recurring friction. For example, the move from DSA to ECDSA [64, 65] reduced public key sizes [66], improving applicability in resource-constrained environments. Yet even this migration came with challenges [67, 68]. Recurring issues include web servers interacting with heterogeneous clients [69] or compliance with differing national standards such as US FIPS [70] versus Russian GOST [71]. Protocols negotiating cryptographic algorithms at runtime provide one way to mitigate such problems, but their implementation and testing can be resource-intensive [7]. Still, these mechanisms are present in software and standards, suggesting that aspects of cryptographic agility have been addressed, although imperfectly [67, 72].

Real-world developments reinforce this perspective. Early PQC migration steps integrated lightweight schemes such as NTRU Prime [73] in tools like TinySSH¹ or OpenSSH². Broader experiments focused on minimalistic changes (see, e.g., [74, 75]). Attempts at more agile solutions revealed how complexity increases with agility. For example, the current approaches [76–79] for making the key agreement protocol IKEv2 [80] quantum-safe, apart from using pre-shared keys [81], introduce significant additional logic, which increases protocol complexity, complicates implementations, and multiplies testing efforts [82]. Taken together, these examples highlight that without systematic agility, every cryptographic transition risks high cost, limited interoperability, and delayed deployment.

It is therefore not surprising that, in the face of the PQC transition, the number of papers mentioning cryptographic agility is rising. Across the literature there is broad consensus that agility is important, if not a cornerstone of any cryptographic transition strategy. Yet despite agreement on its importance, the concept itself remains weakly defined. Most authors pick ad-hoc definitions that suit their individual needs. For example, some authors treat cryptographic agility as an inherent property of systems, others as an engineering practice, and still others as a broader design paradigm. Furthermore, concepts related to cryptographic agility, such as “cryptographic versatility” and “cryptographic interoperability”, are mixed together. As a result, inconsistencies arise in both academic research and practical implementation. This conceptual ambiguity motivates the central question raised by Ott *et al.*: “Where is the research on cryptographic transition and agility?” [14, 37].

To address this issue, we conducted the first systematic study of cryptographic agility. Simply put, this paper explains what cryptographic agility is, what it is not, and where it manifests in real systems. Therefore, we synthesized prior attempts at definition, refined them into a literature-based and subsequently a context-independent definition, clarified their relation to neighboring concepts, operationalized the concept through a layer model, and demonstrated its applicability through three real-world examples. Accordingly, our contributions are:

- 1) We illustrate the variety of existing definitions in the literature and derive their fundamental characteristics (cf. Section III-B). This highlights the lack of coherence in the literature and the potential for misunderstandings.
- 2) We synthesize these findings into a literature-based definition and further refine it to a context-independent definition (cf. Sections III-C and III-D). This provides a precise basis for future research on cryptographic agility.
- 3) We operationalize the concept through a layer model and four overarching domains and position related notions with clear boundaries (cf. Section III-E). This clarifies terminology and enables consistent reasoning across contexts.
- 4) We demonstrate the applicability of our results by analyzing three real-world exemplars, namely OpenSSL, NGINX, and GitLab CI/CD (Continuous Integration/Continuous Delivery), within the software domain (cf. Section IV). This grounds the abstract property of changeability in practical mechanisms and limitations.

The remainder of this paper is structured as follows: Section II outlines our systematic review methodology. Section III presents the results, including our categorization, definitions, layer model and related concepts. Section IV applies these insights to practical examples, while Section V discusses their broader implications. Finally, Section VI explores possible threats to the validity of our studies and Section VII concludes.

II. RESEARCH METHODOLOGY

In this section, we will detail our research protocol, the search and selection process, data extraction, analysis, and synthesis. Fundamentally, we follow the PRISMA 2020 guidelines [83] for systematic literature reviews in selecting the sources for this systematization of knowledge.

A. RESEARCH PROTOCOL

The purpose of the research protocol is to ensure quality by specifying the research questions, defining inclusion and exclusion criteria for the final paper set selection, and applying the quality assurance plan throughout the process. Our study addresses the following four research questions:

RQ1: *How does the current literature define cryptographic agility and which relevant characteristics of cryptographic agility can we extract?*

RQ1 examines the various definitions of cryptographic agility in academic and gray literature, and addresses the lack of consensus on its meaning. It identifies shared aspects of the definitions and clusters them into coherent categories.

RQ2: *What are the defining characteristics of cryptographic agility and to which definition can we synthesize them based on the literature?*

RQ2 synthesizes the results from RQ1 into a literature-based definition of cryptographic agility that unifies the most significant characteristics extracted from the literature.

¹<https://tinyssh.org/>

²<https://www.openssh.com/>

TABLE 1. Selection Criteria.

Inclusion Criteria
1) Primary and secondary studies that explicitly provide their own definition of cryptographic agility or a composite definition based on already existing ones. 2) Studies that are classified as academic literature or specific gray literature, including work in progress, technical and research reports, journal papers, preprints, white papers, conference or workshop contributions, government documents, blog posts, websites, RSS feeds, PhD and master theses.
Exclusion Criteria
1) Duplicates of already included studies. 2) Older versions of an already included study. 3) Gray literature that are videos, podcasts, and webinars. 4) Studies that directly quote another paper's definition and therefore do not provide their own definition of cryptographic agility. 5) Studies that are not available, and hence not analyzable (e.g., the link to a web page is broken or the full text of an article is not accessible). 6) Studies written in any language other than English.

RQ3: *What is a sharpened, context-independent definition of cryptographic agility that goes beyond existing literature?*

RQ3 refines and consolidates the concept of cryptographic agility beyond the definition synthesized from the literature. Building on the results of RQ2, we revisit the key characteristics of cryptographic agility and derive a sharpened and context-independent definition of cryptographic agility.

RQ4: *What are the contextual domains of cryptographic agility and how can its relationship to related concepts be clarified?*

RQ4 investigates how cryptographic agility manifests in different contexts and synthesizes them into the overarching domains of conceptual, software, hardware, and organization. We also clarify the relationship of cryptographic agility to the neighboring concepts of cryptographic versatility and cryptographic interoperability, in order to sharpen conceptual boundaries and avoid terminological ambiguity.

Our selection criteria (Table 1) function as a structured quality control measure to systematically assess articles based on predefined standards. Articles are incorporated into the final selection only if they satisfy all inclusion criteria and are free from any exclusionary conditions.

In the quality assurance process, the first author took the lead in defining each stage, while the other authors reviewed and discussed it until a consensus was reached. Specifically, Table 2 shows the four stages of our quality assurance plan. It ensured that all researchers were involved in each stage, which helped build a common understanding and prevent potential individual bias.

TABLE 2. Quality Assurance Plan.

Stage	Lead Author Role
Research Questions	defines questions
Search Strategy	selects search engines, terms, and steps
Inclusion/Exclusion Criteria	selects main criteria
Category Assignment	assigns definitions to categories

B. SEARCH AND SELECTION

We implemented a structured search process for articles in predefined sources. The final paper set consists of the most relevant literature, which is the result of applying our selection criteria to the individual articles. For our search, we chose IEEE Xplore, ACM Digital Library, Google Scholar and the Google search engine as resources. All four are established and efficient search engines for finding peer-reviewed and gray literature. The utilization of both peer-reviewed and non-peer-reviewed literature enhances the diversity of the final paper set and ensures that definitions from academia and practice are included. This practice is in line with Paez [84] who states that the inclusion of gray literature can lead to less publication bias, enhanced comprehensiveness and a balanced provision of evidence. Because non-peer-reviewed sources vary in rigor, we did not weight sources by perceived quality but let the selection criteria act as a uniform quality gate. Inclusion Criterion 1 admits only sources with substantive definitional content and excludes passing mentions, Exclusion Criterion 4 removes sources that merely quote another definition, and Exclusion Criterion 3 excludes the weakest gray formats such as videos, podcasts, and webinars. We consider all sources that were not peer-reviewed as gray literature. For Google Scholar we used the query (cryptograph* agil*) OR (agil* cryptograph*); for Google Search, IEEE Xplore, and the ACM Digital Library we used `crypto* agil*` (see replication package [85]).

After our search, we found 84 sources with potential definitions of cryptographic agility based on the title, abstract, and content of the source. This initial set contains a broad range of sources, including peer-reviewed articles, white papers, books, and standards. We then applied our selection criteria (see Table 1) to each of the 84 articles, resulting in a final set of 48 articles, nine of which contain more than one definition. Sources were included if they satisfied all inclusion criteria and none of the exclusion criteria. Inclusion Criterion 1 is specific to our research questions and requires that a source explicitly provide its own definition of cryptographic agility or a composite definition based on existing ones. Related terms such as cryptographic transition or cryptographic migration are cryptographic in nature but do not necessarily concern agility, whereas algorithm agility need not be cryptographic at all. Sources using such terms were therefore included only if they satisfied this criterion, and were not treated as separate search targets. The remaining criteria ensure methodological rigor by excluding duplicates, outdated versions, inaccessible sources, and non-English studies. Disagreements during the

application of these criteria were resolved through discussion among all authors until a shared interpretation was reached.

C. DATA EXTRACTION, ANALYSIS, AND SYNTHESIS

We now describe our procedure for extracting, analyzing, and synthesizing the data. Our entire process can be traced and reproduced in detail with the help of our replication package, which contains all tables and mappings [85].

To answer RQ1, we iteratively developed six distinct categories to classify the relevant aspects mentioned in the selected definitions and then assigned the extracted aspects of each definition to these categories. Where cases were unclear, the authors discussed them until agreement was reached. To support classification reliability, we refined the categories iteratively until every aspect of every reviewed definition could be mapped without residual cases. The complete source-by-source mapping is published in the replication package [85] for independent inspection. This iterative mapping unifies heterogeneous terminology and consolidates overlapping perspectives. We further enforce a consistent terminology via a mapping table (e.g., *crypto* → *cryptography*, *updating* → *update*, and normalized related terms such as *information technology systems/information systems/deployed systems* → *systems*). This resulted in a comprehensive and consistent assignment for each definition.

To answer RQ2, we systematically evaluated the categorized data, yielding six categories with between 14 and 31 unique values. We then clustered these values into subcategories to reach a higher level of abstraction (see Table 5). Based on this synthesis, we formulated a literature-based definition of cryptographic agility (cf. Definition III-C).

To answer RQ3, we revisited the key characteristics derived in RQ2 and refined them to exclude context-dependent elements, resulting in a sharpened, context-independent definition (cf. Definition III-D).

To answer RQ4, we analyzed how cryptographic agility manifests across contexts and synthesized them into four overarching domains—conceptual, software, hardware, and organization. We also clarify the relationship of cryptographic agility to related concepts, namely cryptographic versatility (cf. Definition III-E) and cryptographic interoperability (cf. Definition III-E).

III. RESULTS

This section contains an analysis and synthesis of our findings. First, we outline descriptive statistics of the selected articles in Section III-A. Then, we answer our four research questions about the literature's variety in definitions in Section III-B, extract a literature-based definition in Section III-C, provide a clearer context-independent definition in Section III-D, and explore the contextual domains of cryptographic agility and its relation to other relevant concepts in Section III-E.

A. DESCRIPTIVE STATISTICS

This section presents the descriptive statistics of the selected sources, i.e., their publication year, the types of literature, the

authors' affiliation, and the validators. A breakdown of this data can be found in Table 3.

1) Publication Year

As Table 3 shows, the number of publications has almost doubled since 2017 compared to previous years. There was a particular peak in 2021 with eleven publications, followed by 2025 with six. This trend illustrates a significant increase in interest in discussions of the term cryptographic agility.

2) Type of Literature

The type of literature is our second criterion and provides an initial overview of the sources' provenance. We distinguish between peer-reviewed and gray literature. The former in this context means that the paper was part of a scientific publication process, including a peer review. We consider all other kinds of sources, including preprints and RFCs, as gray literature. For our study, the definitions themselves are more important than whether they have been reviewed by a scientific audience, so we also include gray literature. We draw upon data from 24 sources of gray literature and 24 peer-reviewed publications.

3) Author Affiliation

The affiliation can potentially influence the credibility and the reach of the sources. We identified the following categories: Academia, Industry, and Standardization Bodies. The authors of the selected sources can belong to one or more of these three categories. Authors associated with industry form the category with the most selected sources (31), followed by authors belonging to academia (29). Authors affiliated with standardization bodies are the least represented (8).

4) Validator

Our final criterion is “validators”, which indicates how the authors of the selected sources chose to validate their results. We found three categories:

Third Party: A team of independent experts who are not affiliated with the authors of the original source.

Committee: A group of experts in the field who do not necessarily need to be independent, i.e., the source's authors can be members of the committee.

Authors: The authors of the original source validated their own findings without external input.

A source can only be assigned to one of the three validators. If the validator of a source is not apparent, it is assigned to the Author category. A total of 25 sources were assigned to third parties, eight to committee and 15 to authors.

B. RQ1: VARIETY OF DEFINITIONS

By answering this research question, we aim to highlight the diversity of existing definitions for the term cryptographic agility and structure the current state of knowledge in order to provide a foundation for consensus.

Not all papers we considered for our review actually give their own, clear-cut definition. Instead, some just focus on

TABLE 3. Classification of all papers according to our descriptive statistics criteria.

Ref	Year	Literature		Author Affil.			Validator		
		Peer-Reviewed	Gray	Academia	Industry	Stand. Body	3rd Party	Committee	Author(s)
[1]	2019	•		•			•		
[2]	2021	•		•			•		
[3]	2022	•		•	•		•		
[4]	2021		•	•	•				•
[5]	2021	•			•		•		
[6]	2018		•		•				•
[7]	2011		•		•	•		•	
[8]	2017		•	•	•	•		•	
[9]	2019		•		•				•
[10]	2020		•			•		•	
[11]	2023		•		•				•
[12]	2021		•			•		•	
[13]	2015		•		•	•		•	
[14]	2019		•	•	•			•	
[15]	2021	•		•	•		•		
[16]	2016	•		•			•		
[17]	2023	•		•	•		•		
[18]	2020		•		•				•
[19]	2021		•	•	•				•
[20]	2019	•		•			•		
[21]	2023		•	•					•
[22]	2021		•	•			•		
[23]	2021		•	•	•				•
[24]	2021		•	•					•
[25]	2020		•		•				•
[26]	2022	•		•	•		•		
[27]	2012	•		•			•		
[28]	2009		•		•				•
[29]	2022	•			•		•		
[30]	2021	•		•	•		•		
[31]	2018	•			•		•		
[32]	2023		•	•	•	•		•	
[33]	2023	•		•			•		
[34]	2021	•			•		•		
[35]	2023	•			•		•		
[36]	2018		•		•				•
[37]	2023	•		•	•		•		
[38]	2025	•		•	•		•		
[39]	2024		•		•				•
[40]	2024	•		•			•		
[41]	2024		•		•				•
[42]	2025		•	•		•			•
[43]	2024	•		•			•		
[44]	2024	•			•		•		
[45]	2025	•		•			•		
[46]	2025	•		•			•		
[47]	2025	•		•			•		
[48]	2025		•	•	•	•		•	
Σ		24	24	29	31	8	25	8	15

specific subareas of cryptographic agility [7, 13, 16, 22, 27], like the agility of cryptographic protocols [16, 27]. Other papers discuss relevant aspects of cryptographic agility without holistically defining it themselves. They either just quickly describe their understanding of the notion of cryptographic agility [2, 5, 6, 12, 24] or they rely on other research [3, 4, 17, 19, 21]. This approach is taken by the largest group in our reviewed paper set. Sikeridis et al. [11] even do both by first mentioning their rough understanding and then elaborating on other sources' definitions, but without synthesizing the different perspectives.

Apart from the previously mentioned papers, we found several attempts at forging a holistic and context-independent definition of cryptographic agility. Those include:

“True and complete cryptographic agility is the ability to implement, update, change, and remove cryptographic functions from systems and applications on demand, without changing the systems or applications themselves. Cryptographic agility is required across the spectrum of devices, applications, and systems we use today as consumers and business, because cryptography itself is everywhere!

Cryptographic agility should also include the notion of policy management [as] another partial form of agility which allows rules to be applied around what type of crypto might be used by an application or system, relative to what is available on the system.” [9]

“In many ways, cryptographic agility represents the generalization of PQC migration in that it considers not just the current challenge of migrating from our current algorithms to PQC alternatives, but the long term need for ongoing migrations as new attacks and better algorithms motivate the need for updates in our cryptographic standards.” [14]

“Cryptographic agility is the ability of a system to migrate easily from one cryptographic algorithm to another, in a way that is flexible, scalable, and dynamic.” [31]

The attempt given by Mehrez and Omri [31] is more formal than most papers and resembles the common understanding that cryptographic agility has to do with the ability to migrate and also includes appropriate quality attributes such as “flexible” and “dynamic”. Ott et al. [14] provide a detailed view on the topic of cryptographic agility. They themselves see their description rather as a working definition for identifying relevant research questions instead of being a holistic definition itself. We especially see their focus on the post-quantum setting as too narrow for the more general notion of cryptographic agility. Finally, Macaulay and Henderson [9] forged a detailed and comprehensive, yet colloquial definition of cryptographic agility. This description, again, lacks a clear, consistent explanation of the scope and cryptographic entities to which it applies. For instance, for cryptographic entities, it refers to applications and systems but once also to devices. These inconsistencies make the definition less comprehensible to us. Also, we wonder whether the given lists are meant to be exhaustive. For example, we would also see infrastructures as an entity which can be cryptographically agile.

In summary, almost all the reviewed descriptions see cryptographic agility as related to something that facilitates cryptographic migration, as stated in particular by Mehrez and Omri [31]. However, the literature is in disagreement regarding the relation of cryptographic agility to other aspects. Those include whether cryptographic agility is also about protocols dynamically negotiating their used algorithms (something we deem more related to interoperability than agility, see Section III-E), modular architecture of cryptography-related software, management practices for cryptography, or whether it is a purely abstract concept. Also, the level of abstraction is vastly different between the descriptions. In our three examples we assessed one as being too generic [31], one as too narrow [14], and one as inconsistent in its level of abstraction [9]. Hence, even though the content of many definitions resembles our canonical one in large parts, those simplified definitions of cryptographic agility do not reflect the entirety of the literature. Additionally, we see these attempts as both falling short of holistically grasping the concept of cryptographic agility and at the same time lacking clear-cut borders of what is and what is not explicitly part of cryptographic agility.

To clarify this surprisingly complex situation, we applied a systematic and iterative approach for classifying the variety of aspects of the definitions. As a result, the following six distinct categories emerged. We give a suitable question to classify the relevant aspects of a definition at the end of each category:

Context describes the setting in which cryptographic agility is applied in a given instance. In the literature, context ranges from very abstract terms, e.g., *hardware* or *software*, to somewhat more precise ones, like *Internet of Things (IoT)*, *cloud*, or *programming languages* but may go down to a specific device or software component. Thus, the range of the context may be highly individual from abstract concepts like a strategy or processes down to very specific work on a concrete crypto instantiation in a software implementation. We believe context is highly relevant for finding specific measures to apply cryptographic agility in practice and the baseline for a closer examination.

In which technological context is cryptographic agility mentioned?

Modes describe what cryptographic agility is seen as in the articles. For example, it varies from a *cryptographic engineering practice*, to an *approach* or an *objective*. The mode can be seen as the foundation of how cryptographic agility is interpreted for the considered context.

In which form or variety is cryptographic agility presented?

Desired Capabilities describe the extent to which capabilities are provided through cryptographic agility within a specific context, e.g., the capability of *identifying* or *modifying* the cryptographic entities of a system.

What are the desired capabilities provided through cryptographic agility?

Quality Attributes further refine the desired capabilities, i.e., a more concrete description of properties and features. Possible examples are *scalable*, *easy*, or *flexible* [31]. Inclusion of such information improves the quality of the definition by providing additional precision.

Which quality attributes are provided through the desired capabilities?

Cryptographic Entities describe the different types and variants of the existing cryptography within the appropriate context. A cryptographic entity can include anything from keying material and encryption methods to parameter sets or even an entire crypto library.

Which cryptographic entities are affected by cryptographic agility?

Drivers describe the real-world motivations or incentives behind cryptographic agility. For example, the necessary *resilience against quantum attacks* or *compromised classical algorithms* are typically mentioned by authors. Improved handling of new vulnerabilities, e.g., due to software bugs, is another example.

What are motivations for realizing cryptographic agility?

After establishing six distinct categories, we continued our iterative mapping procedure by assigning the definitions to the categories they consider. Table 4 shows the results of this process. Each of the 48 articles states some *Desired Capabilities* of cryptographic agility, and 46 also name the affected *Cryptographic Entities*. In contrast, *Drivers*, which motivate cryptographic agility, represent the least mentioned category with only 31 articles. The other three categories *Quality Attributes* ($n = 39^3$), *Mode* ($n = 40$) and *Context* ($n = 37$) are almost equally distributed. From that we deduce that the *Desired Capabilities* and *Cryptographic Entities* are especially important for a definition of cryptographic agility, while the *Drivers* are less of a defining factor. The other three categories seem to form the middle ground in terms of significance for forming a definition.

The Six Characteristics of Cryptographic Agility

Cryptographic Agility is a *Mode* which provides *Desired Capabilities* with specific *Quality Attributes* concerning *Cryptographic Entities* within a *Context* motivated by *Drivers*.

C. RQ2: LITERATURE-BASED DEFINITION OF CRYPTOGRAPHIC AGILITY

To answer our second research question, we synthesize our findings from the literature review based on the results from RQ1. We provide a comprehensive, literature-based definition for the term cryptographic agility which contains the essential characteristics that hold across all contexts. This provides a common conceptual foundation, before reintroducing specific contexts to capture how agility manifests in conceptual, software, hardware, or organizational levels.

³ n equals number of publications

TABLE 4. The articles' coverage of our categories.

Ref	Context	Mode	Desired Capabilities	Quality Attributes	Cryptographic Entities	Drivers
[1]	•		•		•	•
[2]		•	•	•	•	•
[3]		•	•		•	
[4]			•	•	•	
[5]	•	•	•	•	•	•
[6]	•	•	•	•	•	•
[7]	•	•	•	•	•	•
[8]	•	•	•	•	•	•
[9]	•	•	•	•	•	
[10]		•	•		•	
[11]	•		•	•	•	
[12]	•	•	•	•		•
[13]	•	•	•	•	•	•
[14]		•	•	•	•	•
[15]	•		•	•	•	•
[16]	•	•	•		•	•
[17]	•	•	•	•	•	
[18]	•	•	•	•	•	•
[19]	•	•	•		•	•
[20]	•	•	•	•	•	•
[21]	•	•	•	•	•	
[22]	•	•	•	•	•	•
[23]	•	•	•	•	•	•
[24]	•		•	•	•	
[25]	•	•	•	•	•	•
[26]	•	•	•	•	•	•
[27]		•	•		•	•
[28]			•	•	•	•
[29]	•	•	•		•	•
[30]	•	•	•	•	•	
[31]	•	•	•	•	•	
[32]	•	•	•	•	•	
[33]			•	•	•	•
[34]	•	•	•	•	•	•
[35]	•	•	•	•	•	•
[36]	•	•	•	•	•	•
[37]	•	•	•		•	
[38]		•	•	•	•	•
[39]	•	•	•	•	•	
[40]		•	•	•		•
[41]	•	•	•			•
[42]	•	•	•	•	•	•
[43]	•	•	•	•	•	
[44]	•	•	•	•	•	•
[45]			•	•	•	
[46]	•	•	•	•	•	•
[47]	•	•	•	•	•	
[48]	•	•	•	•	•	
Σ	37	40	48	39	46	31

TABLE 5. Clusters of Values for our definition of cryptographic agility.

Category	Subcategories
Modes	Objective Property Approach (Theoretical, Practical)
Desired Capabilities	Set up Identify Modify (Improve, Add, Remove, Exchange)
Quality Attributes	Flexible Business-continuous Efficient (Time, Cost, Effort, Risk, Resource)
Cryptographic Entities	Keying Material Encryption Methods (Parameters, Implementations, Standards)

Our first step towards formulating a definition is to determine which of the six categories comprise defining attributes for cryptographic agility and which categories only relate to it but are no defining factor. This led us to exclude the categories *Context* and *Drivers*. Context describes the setting in which cryptographic agility is applied and is therefore not a defining characteristic in itself. Context is variable across settings, as what constitutes cryptographic agility in a software library differs from what it means in an organizational process. Including context in the core definition would therefore produce a definition specific to one setting rather than a universally applicable one. Drivers describe the motivations behind cryptographic agility, such as regulatory requirements, security threats, or algorithm obsolescence. They explain why cryptographic agility is needed, but not what cryptographic agility is, and are therefore not a defining characteristic. Excluding both allows a definition of cryptographic agility at its core that holds across contexts. In contrast, the four categories *Modes*, *Desired Capabilities*, *Quality Attributes*, and *Cryptographic Entities* are the foundation of a proper definition. *Modes* describe what cryptographic agility actually is (e.g., a property) and the *Desired Capabilities* in combination with the *Quality Attributes* what it accomplishes (e.g., efficient modification). Finally, the category *Cryptographic Entities* describes the components affected by cryptographic agility.

After selecting the four relevant categories, we derived and unified the most significant values for each category, shown in Table 5. These values help answer the following three key questions that guide the establishment of a literature-based definition of cryptographic agility:

What are the unified modes of cryptographic agility?

Categorizing the modes shows that cryptographic agility is generally considered a (*theoretical* or *practical*) *approach*, an *objective*, or a *property*. Frauenschlaeger et al. describe cryptographic agility as a “dimension” and “aspect” [43]. We consider the underlying idea appropriate, yet find the terms too abstract and insufficiently precise for a unified and formal definition of cryptographic agility.

What are the unified desired capabilities with their associated attributes provided by cryptographic agility? As part of our synthesis, we identified three relevant subcategories for *Desired Capabilities*. These are the capabilities to *set up*, *identify*, or *modify* cryptographic entities. We can divide *modify* further into *improve*, *add*, *remove*, and *exchange*.

The capabilities' quality attribute subcategories are *flexible*, *business-continuous*, and *efficient* in terms of *cost*, *effort*, *time*, *risk*, and *resources*. In our final results, we deliberately exclude overly generic values, such as "great" or "heterogeneous". We also considered the desired capabilities "support" [40] and "coordination" [43] as misleading, since they describe auxiliary or interaction processes rather than distinct capabilities. Hence, we also excluded these in order to create a formal definition.

What are the unified cryptographic entities affected by cryptographic agility? Based on our synthesis we derived the subcategories *keying material* and *encryption method* for cryptographic entities. *Encryption method* can further be divided into *parameters*, *implementations*, and *standards*. Other aspects in the literature we appraise as too generic for consideration are "cryptography", "cryptographic core", and "cryptographic features".

With our subcategories as answers to the questions relevant for the definition at hand, we can formulate the following literature-based definition of cryptographic agility:

Literature-based Definition of Cryptographic Agility

Cryptographic Agility is a theoretical or practical approach, objective, or property which provides capabilities for setting up, identifying, and modifying encryption methods and keying material in a flexible and efficient way while preserving business continuity.

D. RQ3: CONTEXT-INDEPENDENT DEFINITION OF CRYPTOGRAPHIC AGILITY

Building on the literature-based definition established in RQ2, we conducted an additional synthesis to further clarify the concept of cryptographic agility. In short, the literature-based definition (Definition III-C) combines the recurring characteristics found in prior work, whereas the context-independent definition (Definition III-D) reduces them to the single core property of changeability. For this purpose, we revisited four key characteristics of the concept: its mode, desired capability, the role of quality attributes, and the notion of cryptographic entities.

First, we understand cryptographic agility as a *property* inherent to a given context. In our synthesis of the literature, three possible modes emerged: *property*, *approach*, and *objective*. We argue that *property* is the most suitable. An *objective* describes an external goal. This is misleading because cryptographic agility is not a target to be achieved and then forgotten about but a feature of the system under

consideration. In contrast, PQC migration could be considered as an objective since it represents a single, one-time event. An *approach* describes a way of proceeding rather than a characteristic of the system itself. This is misleading because cryptographic agility does not depend on how change is pursued but on whether the system has the built-in property to support change. A *property*, in contrast, refers to an intrinsic feature of a system. Describing cryptographic agility as a property makes it possible to specify and evaluate it clearly within a given context.

Second, we refine the understanding of the desired capabilities. Based on our synthesis, cryptographic agility enables a context to *set up* and *modify* cryptography. We unify these capabilities under the broader notion of *changeability*. Modification can be broken down into the fundamental operations *add* and *remove*, which define the system's ability to integrate new cryptographic entities and eliminate obsolete or insecure ones. Replacement, often discussed in the literature, is a combination of these operations, whereby one entity is removed and another added. Configuration, expressed through *enable* and *disable*, represents the system's capacity to set up cryptography without altering its composition. We highlight these four operations (*add*, *remove*, *enable*, *disable*) because they together capture the essence of what it means for a system to be changeable: They describe the intrinsic mechanisms which allow altering a system's cryptographic entities. Identification of cryptographic entities, while often mentioned in the literature, is a requirement for change but not itself part of changeability.

Third, we deliberately exclude quality attributes from the definition. Attributes such as flexibility, efficiency, or continuity describe how changeability is realized in a specific context. They influence the performance or smoothness of cryptographic modifications but do not determine whether the property of cryptographic agility exists. Including them confounds the definition with context-dependent aspects that vary between contexts. By focusing on changeability itself, we define a property that exists independently of secondary characteristics, making the definition both context-independent and conceptually precise. Excluding these attributes from the definition does not render them irrelevant. Practical attributes such as cost, effort, risk, and operational continuity remain the criteria against which changeability must be assessed in a concrete context, as discussed in Sections V-A and V-B.

Fourth, we employ the term *cryptographic entities* to refer to the affected cryptography and its components. Compared to narrower notions such as keying material or encryption methods, the term cryptographic entities encompasses a wider spectrum. Entities may include individual algorithms and keys, entire protocols, or cryptographic libraries, depending on the context. This abstraction ensures that the property of cryptographic agility can be consistently recognized across different system layers and application scenarios, rather than being tied to specific implementations or artifacts.

Taking these refinements together, we propose the following final, context-independent definition of cryptographic agility as the answer to RQ3:

Context-Independent Definition of Cryptographic Agility

Cryptographic Agility represents the changeability of cryptographic entities.

E. RQ4: DOMAINS OF CRYPTOGRAPHIC AGILITY AND ITS RELATED CONCEPTS

In this section, we move from the context-independent definition (cf. Definition III-D) of cryptographic agility towards a more application-oriented perspective. We first introduce a layer model to capture the various contexts of cryptographic agility and derive its overarching domains, namely the conceptual, software (cf. [8, 9, 19, 37, 47]), hardware (cf. [8, 9, 19, 21]), and organizational domain (cf. [20, 25, 30]). The model is derived from recurring contexts identified in the reviewed literature and should be understood as an open reference model. Unlike assessment-oriented models such as CAMM [33], it is descriptive: it organizes where cryptographic agility manifests rather than assigning maturity levels or scores. Cryptographic agility spans all dimensions, cryptographic versatility is relevant in the hardware dimension, and cryptographic interoperability is relevant in the software and hardware dimensions, where cryptographic mechanisms are provided and used to exchange data securely across systems. On this basis, we first introduce the layer model in detail before turning to the two related concepts of cryptographic versatility and interoperability.

Contextual Layers and Domains of Cryptographic Agility

To clarify how cryptographic agility manifests across different environments, we introduce a layer model that depicts the contexts of cryptography. This model highlights that the property of changeability is not uniform, but appears differently depending on the respective context. For example, changes in the software domain such as libraries typically involve substituting or updating algorithm implementations, whereas changes in the hardware or organizational domain rather require procurement, governance, or supplier management measures. Based on our literature review, we identified 17 unique contexts, which are provided in our replication package. By structuring these contexts, the model systematically illustrates where and how cryptographic agility arises and how dependencies between contexts affect its realization.

Figure 1 depicts our layer model. Each layer represents a distinct context in which cryptographic entities are deployed and also updated. At the innermost level are cryptographic primitives—abstract building blocks such as block ciphers or hash functions—followed by algorithms that instantiate them and are typically implemented in software or hardware. The model expands outwards to libraries, applications, platforms, operating systems, devices, IT infrastructure, and finally the organizational layer. This nested structure emphasizes dependencies: Outer layers build on inner ones and are thereby both

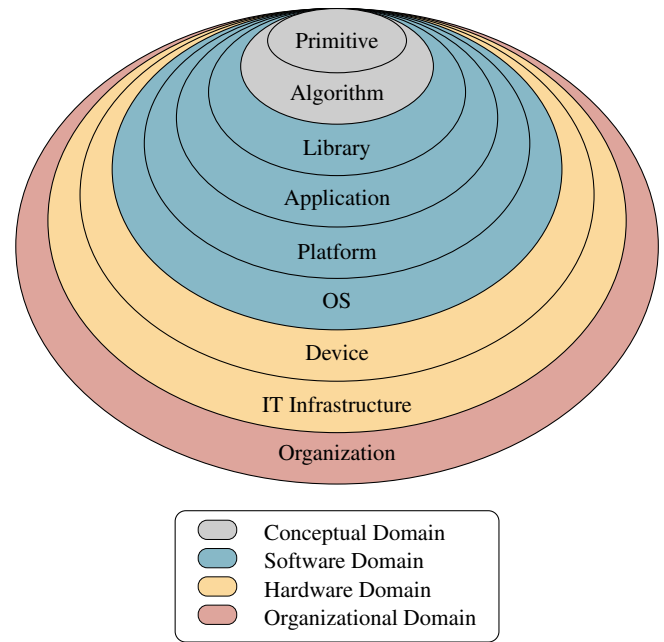


FIGURE 1. Layer Model of Contexts in Which Cryptographic Agility Manifests Across Four Domains. Each Outer Layer Depends on and Is Constrained by the Layers Within It.

enabled and constrained by them. For example, applications depend on libraries or operating system frameworks that implement algorithms, while devices and infrastructure provide hardware-backed services under organizational governance. Table 6 complements the layer model figure with representative examples of cryptographic entities to be changed for each context.

Domains as abstraction. We group the contexts into four overarching domains: the *conceptual domain* (primitives, algorithms), the *software domain* (libraries, applications, platforms, operating systems), the *hardware domain* (devices and infrastructure), and the *organizational domain* (cf. Figure 1). This grouping captures the most common and operationally distinct types of entities relevant for cryptographic agility, while enabling reasoning at a higher level of abstraction. The distinction also explains the granularity of the model: The *conceptual domain* represents the theoretical layer in which cryptographic primitives and algorithms are defined, analyzed, and standardized independently of any specific implementation. The contexts of this domain form the foundation for the realizations on all subsequent layers. Software contexts are more fine-grained because cryptographic entities in software are highly modular, subject to frequent updates, and often nested (e.g., applications depending on other applications or libraries encapsulating multiple algorithms; cf. Table 6). Hardware contexts appear coarser, not because they are less complex but because manufacturers of devices typically encapsulate several cryptographic components (e.g., accelerators, TPMs, enclaves; cf. Table 6) and infrastructures aggregate multiple devices. At the organizational level, comparable subcontexts

TABLE 6. Contexts of the Cryptographic Agility Layer Model with examples of how cryptographic agility is realized.

Layer	Examples of How Cryptographic Agility Is Realized
Primitives	Generic mathematical abstractions keep higher layers functional when the underlying structure changes (e.g., the same key exchange logic operates over finite-field, elliptic-curve, or lattice-based groups such as Module-LWE)
Algorithms	Parameterized configurations prevent code duplication and enable adaptable algorithm behavior (e.g., one AES implementation selecting the key length at runtime); shared validation layers enforce parameters and modes
Libraries	Integration and substitution of cryptographic algorithm implementations (e.g., adding ML-KEM to OpenSSL) while retiring deprecated algorithms such as RC4 and MD5
Applications	Configuration- or policy-based adaptation of cryptographic use (e.g., migrating messaging applications to post-quantum key exchange; disabling outdated TLS versions like 1.0/1.1)
Platforms	Configurable replacement of platform components without disturbing dependent services (e.g., exchanging a web server such as NGINX for another within GitLab without influencing other components or services of the platform)
Operating System	Modular cryptographic frameworks and APIs allow algorithms to be updated or replaced (e.g., swapping legacy kernel crypto modules with PQC-capable ones; adding new primitives to the OS crypto API)
Devices	Replacement or upgrade of hardware-based cryptographic components (e.g., exchanging TPM 1.2 for TPM 2.0; updating smartcards or hardware tokens to support post-quantum algorithms via firmware updates)
IT Infrastructure	Reconfiguration or replacement of infrastructure cryptographic services to adopt newer mechanisms (e.g., switching from RSA-based PKI to ECDSA- or PQC-based PKI; updating VPN and TLS termination systems)
Organization	Adaptation of organizational policies and standards to evolving cryptographic requirements (e.g., adopting NIST post-quantum standards; updating procurement and compliance guidelines to enforce FIPS 140-3 conformity)

are less straightforward to depict, since governance structures, processes, and product strategies are highly individual. For this reason, Figure 1 does not visualize detailed organizational subcontexts and instead introduces representative examples in Table 6.

Representative, not exhaustive. The layer model is not intended as an exhaustive enumeration of all possible contexts, but rather as a reference model highlighting the most representative ones consistently observed in literature and practice. Additional contexts, such as cryptographic protocols, could be added in more detailed analyses. Protocols, for example, are typically implemented in software (as part of a library or application), may rely on hardware features (e.g., HSMs or TPMs), and are governed by organizational standards such as RFCs. This illustrates how changeability may simultaneously depend on factors of all domains. Hence, the model should be understood as open and extensible.

Nested contexts. Even within a single domain, and sometimes even within a single layer, contexts may be nested. This is particularly visible in the software domain: platforms integrate applications, and applications can in turn contain or depend on other applications, nesting contexts within one layer. We illustrate this in Section IV, where GitLab CI/CD (a platform) internally integrates NGINX (an application), thereby forming a layered relationship within the software domain. Such nesting underlines that while the model provides a structured abstraction, concrete deployments often exhibit additional complexity.

Implications for cryptographic agility. Each domain brings characteristic implications for the realization of cryptographic agility and thus provides a domain-specific perspective on its definition:

Conceptual domain. Cryptographic agility in the conceptual domain denotes the property of changeability of abstract cryptographic entities, including primitives and algorithm specifications independent of their implementation. It man-

ifests primarily through the ability to introduce, modify, or deprecate cryptographic designs via research, standardization, or regulatory processes. Although these changes are not operational by themselves, they determine the scope of agility achievable in all other domains.

Software domain. Cryptographic agility in the software domain denotes the property of changeability of software-based cryptographic entities, including libraries, application bindings, and operating system providers. It is shaped by modularity, interface stability, and update mechanisms. Entities can often be substituted rapidly, but only if interfaces are well designed and backward compatibility is maintained. A stable interface alone, however, is not enough: it can hide that a swapped scheme carries different functional guarantees (e.g., a different homomorphic structure or a stateful instead of a stateless signature scheme). This exemplifies an inherent trade-off: the abstraction that enables swapping also conceals differences that callers may depend on. OpenSSL's provider architecture keeps the API stable so algorithms can be swapped without changing application code, but ensuring that a swapped scheme still fulfills what the API promises remains the developer's responsibility, for example through interface contracts, conformance tests, and validation of the new provider (cf. Section IV-A).

Hardware domain. Cryptographic agility in the hardware domain denotes the property of changeability of hardware-based cryptographic entities, including device components (e.g., accelerators, TPMs, HSMs), entire devices, and the infrastructures built upon them. It is limited by physical constraints and lifecycle costs, since changes often require new procurement and depend on manufacturers' support for updated cryptographic features.

Organizational domain. Cryptographic agility in the organizational domain denotes the property of changeability of organizational entities, including cryptographic policies, standards, and suppliers that govern and shape the use of

software and hardware components. It is driven by governance, processes, and product lifecycles, which determine whether cryptographic changes can be integrated without disrupting operations.

Cryptographic Versatility

Having established the layer model and its domains, we now turn to related concepts that complement cryptographic agility. The first of these is *cryptographic versatility*, originally introduced by Richter et al. [2] as the ability of a hardware system to perform multiple different cryptographic tasks. We consider this concept closely related to the hardware domain, where changeability is often limited by physical constraints.

In contrast to *cryptographic agility*, which denotes the *property* of changeability, versatility does not imply that new schemes can later be added or old ones removed. Instead, it describes a static capability inherent to hardware. A versatile device may, for instance, provide acceleration for AES, SHA-2, and ECC in parallel, but it cannot adapt to support post-quantum cryptography unless this was anticipated at design time. This ability may also include support for *hybrid cryptographic schemes*, where classical and post-quantum algorithms are combined to balance trust in established primitives with protection against emerging quantum threats [86, 87]. Versatility is therefore not a sub-property of agility but a distinct ability that complements it in contexts where hardware constraints inherently limit changeability.

Cryptographic Versatility

Cryptographic versatility is the *ability* of hardware entities to support multiple cryptographic schemes by design, including hybrid operations.

Cryptographic Interoperability

In addition to versatility, a second concept arises in the context of RQ4, namely *cryptographic interoperability*. Only a subset of the literature on cryptographic agility addresses it explicitly and then without a uniform terminology: some authors refer to interoperability, others to compatibility, and some blur the line with agility. This lack of precision has contributed to the frequent conflation of both concepts. Historically, this conflation was common especially in the context of protocols. There, the similarities between the common algorithms allowed protocols to dynamically negotiate the exact cryptographic parameters for a connection. This made them both interoperable and reduced the actual agility to a software or library issue. However, the great variation in the characteristics of the PQC algorithms means that they are usually not a drop-in replacement for one another but that the context has to adapt to their specific features. Thus, merging all the concepts together under the term of cryptographic agility is no longer applicable. To properly define cryptographic interoperability for the current situation, we first review how it is discussed in prior work and then contrast it with agility.

Existing literature frames interoperability primarily as a requirement that accompanies cryptographic agility. McKay defines it broadly as “the ability to communicate and exchange information between systems” [8]. Mehrez and Omri [31] as well as the authors of RFC6421 [7] describe interoperability as a partial objective of agility, since cryptographically agile solutions must also ensure communication across different implementations. Mehrez and Omri further emphasize that protocol designers carry responsibility for interoperability by specifying mandatory-to-implement algorithms. Other works associate interoperability with backward compatibility: Fan et al. highlight its role in integrating post-quantum cryptography without disrupting existing processes [15], and RFC6421 underscores backward compatibility as a mandatory requirement in the RADIUS protocol [7]. Paul et al. note that newer protocol versions must continue to support secure communication across implementations [22], while Moustafa et al. stress the importance of uniform standards as a prerequisite for interoperability [6]. At the same time, several studies caution that excessive backward compatibility undermines security by prolonging the use of deprecated algorithms [9][88] and enabling downgrade attacks [89, 90]. These notions already show the high cost in terms of complexity of interoperability, also compared with agility. Furthermore, interoperability is still most frequently discussed in the context of protocols (e.g., [1, 7, 15, 22, 23, 31]). Building on this foundation, we clarify the distinction between interoperability and agility and emphasize that the relationship between cryptographic agility and interoperability is unidirectional.

First, agility facilitates interoperability. Since agility encompasses the ability to add, enable, disable, and remove cryptographic entities, it enables systems to adapt their supported cryptographic mechanisms to the requirements of secure communication. For instance, if legacy support is necessary to maintain compatibility with outdated systems, a cryptographically agile system can simply enable or add the relevant algorithms. If new secure algorithms must be adopted due to regulatory or security requirements, they can be integrated without disruption. In both cases, these changes would increase the cryptographic interoperability of the system. Conversely, when legacy support is no longer desired, agility also allows these algorithms to be disabled or fully removed, increasing security by reducing interoperability. This illustrates how interoperability depends on cryptographic agility. Furthermore, interoperability should be understood as tied to the set of active cryptographic mechanisms in a system. Even if a system could easily enable additional algorithms, these do not contribute to its current interoperability until it actually does so.

Second, cryptographic interoperability does not, by itself, determine cryptographic agility. The ability of a system to communicate securely with many peers through multiple cryptographic mechanisms says nothing about the ease of changing its cryptography. For example, supporting a wide range of algorithms does not automatically imply that they can be added, removed, or replaced efficiently. Interoperability

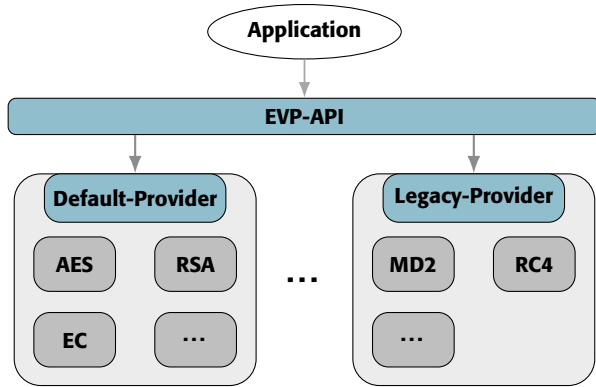


FIGURE 2. OpenSSL Provider Architecture Centered on the EVP API. The EVP Abstraction Decouples Applications from Algorithm Implementations; Providers Can Be Added, Removed, or Replaced Without Recompiling Dependent Applications.

therefore only indicates the variety of secure communication possible at a given point in time, but neither enables nor constrains agility. This distinction is particularly relevant considering cryptographic migration, such as the upcoming PQC transition. Migration typically aims at increasing security at the cost of interoperability by deprecating legacy schemes. In such cases, agility is the decisive property, as it determines the efficiency of disabling or removing obsolete algorithms from a system.

Cryptographic agility says nothing about which mechanisms are currently active. Cryptographic interoperability, in turn, reflects exactly that: the set of mechanisms a system actively uses to communicate securely at a given point in time. The two concepts are therefore distinct but related, and we refine the notion of interoperability as follows:

Cryptographic Interoperability

Cryptographic Interoperability is the ability of a system to communicate securely with others, using a variety of cryptographic mechanisms at the same time.

IV. CRYPTOGRAPHIC AGILITY IN PRACTICE

In this section, we apply the concepts from Section III to show how cryptographic agility manifests in specific contexts. The exemplars, i.e., OpenSSL, NGINX, and GitLab CI/CD, are widely deployed and maintained, which makes them relevant for real-world cryptographic agility considerations. Throughout, we highlight each example's role within the layer model (cf. Figure 1), explain how cryptographic agility is realized and constrained, and assess its implications for interoperability (cf. Section III-E).

A. OPENSSL AS A CRYPTOGRAPHICALLY AGILE LIBRARY

OpenSSL⁴ is a software library for cryptography that resides at the library layer of our layer model (cf. Figure 1). It provides

cryptographic primitives and algorithms to a broad spectrum of applications, ranging from embedded devices to large-scale web services. Because it sits at the interface between low-level algorithms and higher-level applications, its treatment of cryptographic agility strongly influences other layers.

Realization of cryptographic agility. OpenSSL realizes cryptographic agility primarily through its provider architecture, introduced with version 3.0. The architecture is illustrated by Figure 2. Providers are modular containers for algorithm implementations that can be loaded dynamically at runtime. This design allows administrators or developers to add and remove cryptographic algorithms without recompiling dependent applications, as long as those applications rely on the unified Envelope (EVP) API. The EVP API abstracts the details of individual algorithms by exposing a consistent interface for symmetric and asymmetric operations, digests, and key management. Through this abstraction, applications can switch algorithms by altering configuration or provider settings rather than modifying source code. Further agility is supported by OpenSSL's configuration system, which permits runtime selection of default providers, algorithm preferences, and security policies. Since version 3.5.0, the library has also included support for post-quantum algorithms, demonstrating its extensibility to entirely new cryptographic families. In summary, the provider architecture, the EVP API, and the runtime configuration system are the key mechanisms that enable cryptographic agility in the context of OpenSSL (cf. OpenSSL documentation^{5 6 7}).

Constraints of cryptographic agility. Despite this modular design, OpenSSL faces structural limits. The EVP API must be used consistently; legacy applications that call lower-level APIs (e.g., directly invoking algorithm-specific functions) cannot benefit from the provider model and must be rewritten to gain cryptographic agility. Furthermore, OpenSSL lacks a unified mechanism for centralized cryptographic policy enforcement across multiple applications. Policies such as *disallow RSA with key sizes below 2048 bits* must be configured separately for each consuming application, leading to potential misconfiguration. Dynamic loading of providers improves flexibility but does not guarantee the correctness or trustworthiness of a new implementation, which remains an operational and verification effort. Finally, integration of new cryptographic primitives often requires coordination with consuming applications to ensure correct parameter handling, especially in the case of emerging PQC algorithms with non-standardized interfaces. In summary, the main constraints on cryptographic agility in OpenSSL are legacy use of low-level APIs, lack of centralized policy management, and trustworthiness challenges with dynamically loaded providers.

Interoperability. OpenSSL directly impacts cryptographic interoperability by determining which algorithms and protocol

⁵<https://docs.openssl.org>

⁶<https://github.com/openssl/openssl/blob/master/docs/OpenSSL300Design.md>

⁷<https://github.com/openssl/openssl/blob/master/README-PROVIDE.RS.md>

⁴<https://docs.openssl.org/master/man1/openssl/>

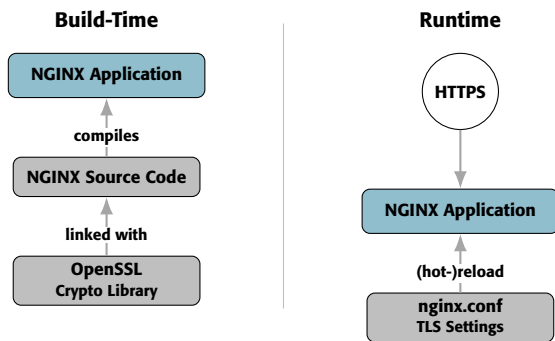


FIGURE 3. NGINX Cryptographic Agility at Build Time and Runtime. The Backend Is Fixed at Compile Time; TLS Settings Can Be Reconfigured and Reloaded Without Restarting.

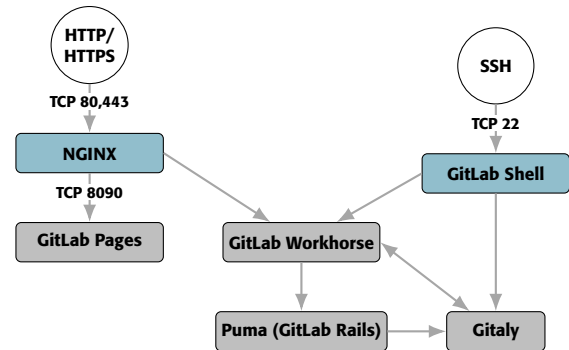


FIGURE 4. Cryptography-Relevant Components in GitLab CI/CD. NGINX Handles TLS Termination and GitLab Shell Manages SSH; Together They Form the Primary Cryptographic Endpoints of the Platform.

versions are available to higher layers. For example, the cipher suites that a TLS implementation can negotiate depend entirely on the algorithms exposed by OpenSSL. However, because policy settings are decentralized, achieving consistent interoperability across a heterogeneous system landscape can be difficult. In practice, interoperability is enabled by the library but still mostly depends on the outer context, usually applications (cf. Figure 1), to properly handle the algorithms and maintain the policy settings.

B. NGINX AS A CRYPTOGRAPHICALLY AGILE APPLICATION

NGINX⁸ is a high-performance, open-source web server and reverse proxy that resides at the application layer of our layer model (cf. Figure 1). Although its core functionality is not limited to cryptography, it integrates cryptographic operations through external libraries such as OpenSSL and thereby inherits both strengths and weaknesses from the underlying library.

Realization of cryptographic agility. NGINX realizes cryptographic agility primarily through its configuration-driven design. Administrators can enable, disable, or prioritize specific protocols, algorithms, and parameter sets directly in configuration files without modifying source code. At runtime, changes to TLS versions, ciphersuites, and key lengths can usually be applied by reloading the configuration, minimizing downtime. At compile-time, NGINX can be built against different cryptographic libraries or library versions, which allows operators to migrate to newer backends (e.g., OpenSSL with PQC support) without altering NGINX itself. This dual mechanism, namely runtime configuration for fine-grained control and compile-time linking for backend replacement, gives operators substantial flexibility in adapting cryptography to evolving requirements. In summary, cryptographic agility in NGINX is realized through its runtime configuration model and its ability to switch underlying cryptographic libraries at build time (cf. NGINX documentation^{9 10 11}).

Constraints of cryptographic agility. NGINX's agility is constrained by its strong dependency on the capabilities of the linked library, most commonly OpenSSL. If the underlying library lacks support for a new primitive, NGINX cannot provide it. Furthermore, compile-time linking to a specific library version reduces flexibility, since migration to an alternative backend typically requires recompilation and sometimes code-level adjustments. Another constraint lies in the limited granularity of policy enforcement: while administrators can configure cipher priorities, enforcing organization-wide rules across many deployments requires external management tools. In summary, the main constraints on cryptographic agility in NGINX are its reliance on the underlying cryptographic library, the need for recompilation when switching backends, and limited native support for centralized policy enforcement.

Interoperability. NGINX plays a central role in establishing cryptographic interoperability for web services. Its configuration determines which TLS versions and ciphersuites can be negotiated with clients, directly impacting the range of peers it can communicate with. Enabling older algorithms improves backward compatibility but increases the risk of downgrade attacks, whereas disabling them raises security but may cut off legacy clients. Thus, NGINX illustrates how interoperability is shaped by cryptographic agility: changes in configuration or backend libraries translate into changes in the set of secure communication partners.

C. GITLAB CI/CD AS A CRYPTOGRAPHICALLY AGILE DEVSECOPS PLATFORM

GitLab CI/CD¹² is a widely used DevSecOps platform that we classify at the platform layer of our layer model (cf. Figure 1). As a platform, it integrates multiple services such as runners, registries, web servers, and repositories, which together provide continuous integration and deployment workflows. Its relevance for cryptographic agility lies in the way these services coordinate security-critical tasks like code signing, artifact integrity verification, and secure communication across the software delivery process.

⁸<https://nginx.org/>

⁹<https://nginx.org/en/docs/>

¹⁰<https://nginx.org/en/docs/configure.html>

¹¹<https://github.com/nginx/nginx>

¹²<https://about.gitlab.com>

Realization of cryptographic agility. Cryptographic agility in GitLab CI/CD is realized through its extensible pipeline model and the ability to integrate both internal and external cryptographic components. Internally, TLS termination and negotiation are handled via NGINX as a reverse proxy, while GitLab Shell manages SSH-based interactions. For artifact signing and integrity protection, GitLab integrates with tools such as GPG or Cosign. Externally, pipelines can invoke cryptographic libraries (e.g., OpenSSL), command-line utilities, or key management systems. This design makes it possible to add or replace cryptographic mechanisms without altering GitLab's core codebase. Security standards can be enforced directly in jobs, and key material can be rotated automatically via vault integration. Gradual rollout of cryptographic updates across projects or environments further reduces operational risk during migrations. In summary, GitLab CI/CD realizes cryptographic agility through pipeline extensibility, integration of internal services (NGINX, GitLab Shell, artifact signing), and external tool orchestration (cf. GitLab documentation^{13 14 15}).

Constraints of cryptographic agility. Agility in GitLab CI/CD is limited by the diversity of the environments it orchestrates. Runners, container images, and deployment targets must all support the chosen algorithms and parameters; otherwise, inconsistencies and failures occur. Because GitLab itself offers little native cryptographic functionality, support depends on external components whose correctness and timeliness must be assured separately. Coordinating upgrades across diverse teams and environments is complex, and GitLab provides only limited means to enforce uniform cryptographic policies across all pipelines. In summary, the main constraints on cryptographic agility in GitLab CI/CD are dependencies on external components, the complexity of diverse environments, and limited native policy enforcement.

Interoperability. GitLab CI/CD influences cryptographic interoperability by orchestrating how algorithms and protocols are applied across software delivery pipelines and integrated services. TLS interoperability depends on the NGINX proxy configuration, while SSH compatibility is tied to GitLab Shell. Artifact verification requires alignment between signing tools (e.g., GPG, Cosign) and downstream verification processes. Registry interactions rely on consistent TLS and token handling across environments. By coordinating these internal and external components, GitLab extends interoperability across a wide range of tools and platforms. At the same time, differences in cryptographic support between components can lead to fragmentation, requiring careful coordination and phased migration. Thus, GitLab CI/CD exemplifies how interoperability in complex application environments is both enabled and constrained by the extent of cryptographic agility.

D. CROSS-DOMAIN DEPENDENCIES

Across the three exemplars, a common pattern emerges: cryptographic agility at higher layers depends on changeability at lower ones, where OpenSSL provides the algorithmic foundation, NGINX exposes it through configuration, and GitLab CI/CD coordinates it across multiple integrated services. This illustrates why cryptographic migrations require coordinated effort across layers rather than isolated algorithm replacements. In practice, practitioners should target the lowest layer that provides a stable abstraction (e.g., the OpenSSL provider interface) and enforce cryptographic policy as centrally as each layer permits.

The software domain highlights those cross-layer interactions, e.g., between the *library* and *application* layer, especially well: open-source software components expose the most direct and frequent mechanisms for cryptographic change, such as algorithm substitution and library updates, and are therefore most accessible for empirical analysis. In contrast, the hardware and organizational domains evolve on longer timescales and with limited public transparency. This constrains empirical observation and motivates focusing on software as the most analyzable layer.

Many real-world migration problems do not just need coordinated efforts across layers but across domains. One example spanning all domains is software that requires dedicated cryptographic hardware which might be, in turn, subject to supply chain regulations. Another concrete example is the interconnection between the algorithm layer and the application layer for Partially Homomorphic Encryption (PHE). As their homomorphic properties are usually baked into their applications, creating an abstraction layer like in OpenSSL (cf. Section IV-A) is significantly harder [91]. Lightweight libraries such as LightPHE or TenSEAL do provide such an abstraction, exposing several partially homomorphic algorithms behind a unified interface, but swapping the underlying algorithm can shift the mathematical structure (e.g., from an additively to a multiplicatively homomorphic group), so the stable interface preserves the API surface but not the functional guarantees callers depend on. Switching those applications to PQC-ready Fully Homomorphic Encryption (FHE) schemes, on the other hand, does not only change the whole software stack but also imposes severe performance restrictions [92]. Consequently, these cross-domain dependency-intensive instances are both harder to migrate and harder to make cryptographically agile. However, cryptographic agility is especially important there, as an ad-hoc migration is impeded by their inherent complexity.

The combination of the hardware and organizational domains being more opaque and the complexity of domain-spanning dependencies makes analyzing those cases more challenging and pushes it out of this paper's scope. Nevertheless, they often represent important parts of our infrastructure and applying the crypto-agility research in such large case studies is a crucial trajectory of future research.

¹³<https://docs.gitlab.com/development/architecture/>

¹⁴<https://docs.gitlab.com/omnibus/settings/ssl/>

¹⁵<https://gitlab.com/gitlab-org/gitlab>

V. DISCUSSION

In this section, we build on the results of Section III and their practical manifestations in Section IV in order to provide a broader discussion of cryptographic agility. We highlight the inherent complexity of realizing it across contexts (cf. Section V-A), examine the challenges of assessing its extent (cf. Section V-B), and clarify its conceptual distinction from post-quantum cryptographic migration (cf. Section V-C).

A. THE COMPLEXITY OF AGILITY AND INTEROPERABILITY

Introducing agility means introducing additional measures to the respective entities. These include, e.g., flexible interfaces in the software domain or negotiating supplier contracts containing options to change the procured hardware. At the same time, some of these measures also help with other requirements. For example, interfaces are also part of clean software engineering principles, and flexible contracts are part of risk management. Thus, cryptographic agility comes with additional work overhead and by that increases the complexity of the related projects but can also reduce the complexity by limiting the amount of possible (untracked) dependencies.

Striving for maximal interoperability across all contexts, on the other hand, can generate significant overhead. Large pools of supported algorithms and modes, combined with backward compatibility requirements, expand the codebase, add abstraction layers, and complicate decision logic. This complexity raises costs for implementation, testing, and maintenance [14, 26]. Furthermore, it can reduce security by enlarging the attack surface, prolonging the use of deprecated algorithms, and creating opportunities for misconfiguration.

Similarly, striving for high levels of cryptographic agility comes with engineering costs. For example, provider architectures such as the one in OpenSSL require all consuming applications to use a stable abstraction layer consistently. Legacy code that bypasses this abstraction must be rewritten to benefit from it. Beyond implementation effort, migration periods in which old and new mechanisms coexist introduce security risks. If negotiation and fallback behavior are not carefully controlled, such periods can increase the risk of downgrade attacks [89, 90]. Changeability is further bounded when the affected entity carries functional properties that must be preserved. Partially homomorphic schemes illustrate this: a change must trade off cryptographic migration, performance overhead, and the functional guarantees the surrounding system depends on (cf. Section IV-D).

Effective engineering of cryptographic systems therefore requires prioritization. Insufficient agility leaves systems unable to respond to disruptive change, while striving for maximal agility increases the implementation workload. As not every system will display perfect agility, we will always need cryptographic interoperability to some extent but have to keep in mind its inherent cost in complexity. Consequently, organizations and system designers must decide whether the primary need is to ensure resilience against emerging threats or to maintain compatibility with diverse peers, and must implement agility or interoperability mechanisms accordingly.

Instead of generic solutions, the concepts must be realized in ways that align with the domain-specific requirements.

Consideration: Complexity vs. Agility and Interoperability

Cryptographic agility comes at a cost of additional work but can even decrease complexity. High levels of cryptographic interoperability can, however, without clear focus, lead to excessive complexity and reduce security. Thus, it is essential to distinguish between *cryptographic agility* and *cryptographic interoperability* and to pursue targeted, context-specific solutions.

B. ASSESSING CRYPTOGRAPHIC AGILITY

In order to be able to make statements about the extent of the realized cryptographic agility in a specific context (e.g., a device or software library), the question arises as to what extent cryptographic agility can be measured. Several approaches have been proposed, such as the Crypto-Agility Maturity Model (Camm) [33], which defines maturity levels with associated requirements, or the broader property sets introduced by Mehrez and Omri [31]. These models provide useful orientation but should not be mistaken for universally applicable metrics.

A universal measurement is hardly feasible because cryptographic agility spans multiple dimensions. Depending on the context in which agility manifests, different cryptographic entities are affected and must meet different quality attributes. In a library, agility concerns the ability to exchange algorithm implementations efficiently, whereas at the organizational layer it relates to updating policies or suppliers with minimal disruption. These differences illustrate that cryptographic agility is not uniformly defined across contexts and that the associated quality attributes, such as efficiency, continuity, or flexibility, vary accordingly. Our layer model captures this heterogeneity by distinguishing between conceptual, software, hardware, and organizational domains and by specifying the contexts within them. It thus highlights that assessments cannot be generalized but must be tailored to the context in which agility is realized. Our practical demonstration in Section IV covers the software domain only, while the hardware and organizational domains remain conceptual and require further empirical validation.

Against this background, it is more useful to view cryptographic agility as a spectrum that should be assessed relative to clearly defined requirements within a given context rather than by applying universal scales such as fixed maturity levels or percentage values. In practice, this starts with clearly scoping the context and identifying which cryptographic entities can be changed and how. OpenSSL illustrates this well: algorithms are exchanged through the provider architecture, and applications interact with them through the EVP API without needing to be recompiled. Security policies such as disabling weak algorithms can be configured centrally for a single application

via its OpenSSL configuration, though not across applications. Practitioners can then evaluate concrete requirements such as whether algorithms can be replaced without modifying application code, whether cryptographic policies can be enforced centrally, and how much effort a migration to a new algorithm requires. Additional requirements from models such as CAMM [33] or Mehrez and Omri [31] can then be applied to structure a more comprehensive assessment.

Consideration: The Assessment of Cryptographic Agility

Cryptographic agility cannot be universally quantified, since the relevant entities and quality attributes vary across contexts. Assessments should build on established models, but must always be tailored to the specific context in which agility is realized.

C. DISTINGUISHING CRYPTOGRAPHIC AGILITY FROM PQC MIGRATION

A frequent point of discussion is the relationship between cryptographic agility and post-quantum cryptographic (PQC) migration. Although often mentioned together, PQC migration and cryptographic agility are conceptually distinct. Cryptographic agility is a property of a given context, describing its capacity to add, enable, disable, and remove cryptographic entities in a sustainable and repeatable way. It describes how well the structure of systems, infrastructures, or organizations accommodates change, regardless of whether this change is incremental or disruptive. By contrast, PQC migration denotes a singular event: a targeted transition from classical to post-quantum algorithms, typically triggered by external drivers such as the emerging quantum threat, a regulatory mandate, or the completion of standardization milestones, as discussed by Näther *et al.* [93]. Migration, therefore, does not constitute a property of the system itself, but rather a concrete process executed at a specific point in time. Considering our previously introduced modes (cf. Section III-B), PQC migration could be depicted as an objective.

Despite this difference, the two are tightly connected. The success and efficiency of PQC migration directly depends on the degree of agility present in the relevant contexts. In the software domain, modular libraries and flexible APIs determine whether algorithms can be substituted or extended without rewriting applications. In the hardware domain, devices such as HSMs or TPMs may either accelerate or constrain migration, depending on whether they can be upgraded to support new primitives. In the organizational domain, clear governance, procurement rules, and process structures provide the necessary framework to enforce deprecation of vulnerable algorithms and adoption of standardized PQC schemes.

Moreover, PQC migration often requires an intentional reduction of interoperability. To eliminate downgrade risks and meet standardization requirements, insecure legacy schemes must be disabled or removed, thereby narrowing the range of

systems with which secure communication remains possible. Here agility provides the decisive factor: highly agile systems can disable or remove obsolete algorithms in a controlled and efficient way, while less agile ones risk prolonged coexistence of old and new cryptography, increasing exposure to downgrade attacks. Thus, cryptographic agility facilitates timely migration, whereas interoperability mitigates the disruptions caused by entities whose lack of agility prevents swift migration.

Consideration: Agility as Enabler of PQC Migration

Cryptographic Agility enables continuous change across contexts, whereas migration represents a one-time security objective. Without agility, migration becomes costly, fragmented, and error-prone; with agility, it can be executed in a structured, secure, and efficient manner.

VI. THREATS TO VALIDITY

In this section, we discuss potential threats to the validity of our study and how we mitigated them. We structure this discussion based on the widely recognized framework by Ampatzoglou *et al.* [94], which categorizes threats into study selection validity, data validity, and research validity.

A. STUDY SELECTION VALIDITY

Study selection validity concerns the process of identifying and including relevant studies in our analysis. In order to find the most relevant studies for our research questions we constructed dedicated search strings for Google Scholar, the Google search engine, the ACM Digital Library, and IEEE Xplore. We used these four search engines for discovering sources in several digital libraries to mitigate the resource bias. To moderate risks associated with bias, we ensured an almost balanced number of authors from academia ($n = 29$), industry ($n = 31$), and standardization bodies ($n = 8$) as well as gray ($n = 24$) and peer-reviewed ($n = 24$) literature. This is illustrated in Table 3. Additionally, we rigorously applied a set of inclusion and exclusion criteria, ensuring that studies irrelevant to our research were excluded (cf. Table 1).

We acknowledge, however, that we focused only on studies published in English. While this may introduce a language bias, our preliminary search identified a limited number of relevant studies in other languages, which we believe does not significantly affect the validity of our results. Furthermore, our use of Google Scholar and Google Search introduces a ranking bias, as both engines prioritize results based on popularity and citation counts rather than relevance to our research questions. As a result, some sources may be captured unevenly, including preprints such as those on arXiv, particularly in a fast-moving area where terminology is still evolving.

B. DATA VALIDITY

Data validity relates to the accuracy and reliability of the data extracted from the selected studies. Given the relatively small number of papers included in our analysis ($n = 48$), we consider the set to be highly relevant to our research questions and representative of the current state of the field. Furthermore, we employed multiple reviewers during data extraction to minimize subjective bias and random errors. Each reviewer performed independent checks, and we conducted cross-validation to confirm consistency in data interpretation.

Although we did not perform a formal quality assessment of the included studies, our strict inclusion criteria ensure that only papers with clear methodologies and substantial contributions to the field are considered. This approach helps exclude lower-quality publications regardless of their format. Including gray literature nonetheless broadens the evidence base and reduces publication bias. Because these sources still differ in rigor, some unevenness in coverage may remain, which adds to the ranking bias noted in Section VI-A.

C. RESEARCH VALIDITY

Ampatzoglou et al. [94] mention that the lack of repeatability, the lack of coverage of research questions, the lack of comparable related work and the lack of generalizability threaten the validity of studies.

As we documented the exact search strings used for all four search engines, our search strategy can be reproduced. We also provide a replication package for the data extraction so that independent researchers are able to reproduce the whole procedure. Given the fast-moving nature of PQC-related standardization and terminology, we note that the present review represents a snapshot of the literature at the time of search. The replication package [85] can serve as a starting point for follow-up search passes as the field evolves. Furthermore, we ensured the coverage of our research questions by the precise formulation following the PRISMA 2020 statement [83]. Within Section III, which lists our selected papers (see Table 4), we made sure to include the most relevant articles in the context of cryptographic agility. We did not find a similarly systematic approach in the literature. We believe that our study is sufficiently generalizable, as it encompasses a broad spectrum of academic and gray literature from various venues, providing a comprehensive overview of the topic at hand.

D. DEFINITION VALIDITY

Within RQ1 we establish six categories in order to map every aspect of the reviewed definitions to one of these categories.

As we have only used the reviewed literature for this, we cannot make any statements about the general validity and complete coverage of our categories. The categories so far fully cover all cryptographic agility definitions we have encountered in our work, as demonstrated in Table 4. All of the aspects in these definitions can be mapped to one of the categories we defined.

Given the wide range of definitions, certain elements may have been incorporated into the literature-based definition

of cryptographic agility in ways that could benefit from refinement. For example, in the context of data synthesis, interoperability was initially considered part of business continuity, which does not align with the current understanding of the concept. We addressed this challenge with our fourth research question, aiming to clarify and distinguish existing terminology and to develop a new taxonomy that better aligns with the evolving needs in this field of research.

In conclusion we employ a robust methodology and adhere to well-established frameworks and practices. We believe these efforts have minimized the impact of potential biases and errors in our study, ensuring the reliability of our conclusions.

VII. CONCLUSION

This paper provides the first systematic study of cryptographic agility. We synthesized prior attempts at definition, refined them, and established a conceptual foundation that clarifies its scope and relation to neighboring terms.

To answer RQ1, we analyzed existing definitions and mapped their aspects into six categories: *context*, *mode*, *desired capabilities*, *quality attributes*, *cryptographic entities*, and *drivers*. To answer RQ2, we synthesized these results into a literature-based definition that unifies the most significant characteristics across prior work, providing the first systematic definition derived entirely from the existing body of knowledge. To answer RQ3, we extended this foundation conceptually and derived a refined, context-independent definition that isolates agility as the property of changeability of cryptographic entities. To answer RQ4, we introduced a layer model that organizes contexts into four overarching domains—conceptual, software, hardware, and organization—and clarified the relation of agility to the related concepts of versatility and interoperability.

We demonstrated the applicability of our results through three real-world exemplars from the software domain: OpenSSL, NGINX, and GitLab CI/CD. These cases showed how agility is realized in practice, which constraints limit it, and how it interacts with interoperability. The exemplars validate the framework in the software domain only. The other domains remain conceptual. Future work should extend the empirical validation beyond software to hardware and organizational entities, especially case studies with strong cross-domain dependencies, and investigate context-specific assessment approaches for cryptographic agility.

In our discussion, we highlighted broader considerations that extend beyond individual cases. We showed how cryptographic agility is both necessary and complex, how its assessment depends on contextual factors, and how it is closely tied to migration scenarios such as post-quantum cryptography.

Taken together, our results establish a clear conceptual foundation for cryptographic agility. They provide terminology, structure, and examples that enable consistent reasoning across contexts and domains. We expect this work to guide future research and practical efforts in building systems that can accommodate cryptographic change securely, efficiently, and sustainably.

Reviewed Literature

- [1] O. Grote, A. Ahrens, and C. Benavente-Peces, “A Review of Post-quantum Cryptography and Crypto-agility Strategies,” in *2019 International Interdisciplinary PhD Workshop (IIPhDW)*, 2019, pp. 115–120.
- [2] S. Richter, M. Thornton, I. Khan, H. Scott, K. Jaksch, U. Vogl, B. Stiller, G. Leuchs, C. Marquardt, and N. Korolkova, “Agile and Versatile Quantum Communication: Signatures and Secrets,” *Phys. Rev. X*, vol. 11, p. 011038, Feb 2021.
- [3] C. Badertscher, M. Ciampi, and A. Kiayias, “Agile Cryptography: A Universally Composible Approach,” Cryptology ePrint Archive, Paper 2022/1367, 2022. [Online]. Available: <https://eprint.iacr.org/2022/1367>
- [4] A. Badari and A. Chaudhury, “An Overview of Bitcoin and Ethereum White-Papers, Forks, and Prices,” 2021. [Online]. Available: <http://dx.doi.org/10.2139/ssrn.3841827>
- [5] C. Ma, L. Colon, J. Dera, B. Rashidi, and V. Garg, “CARAF: Crypto Agility Risk Assessment Framework,” *Journal of Cybersecurity*, vol. 7, no. 1, p. tyab013, 05 2021.
- [6] N. Moustafa and V. Soukharev, “CRYPTO AGILITY IS A MUST-HAVE FOR DATA ENCRYPTION STANDARDS,” <https://www.cigionline.org/articles/crypto-agility-must-have-data-encryption-standards/>, 2018, accessed: 2024-07-04.
- [7] D. Nelson, “Crypto-Agility Requirements for Remote Authentication Dial-In User Service (RADIUS),” RFC 6421, Nov. 2011.
- [8] National Academies of Sciences, Engineering, and Medicine, *Cryptographic Agility and Interoperability: Proceedings of a Workshop*, A. Johnson and L. Millett, Eds. Washington, DC: The National Academies Press, 2017.
- [9] T. Macaulay and R. Henderson, “CRYPTOGRAPHIC AGILITY IN PRACTICE,” Whitepaper, https://assets.website-files.com/5bd73d456f7b3f2db2bbb95/5c76a740dcc2cc4646a06805_ISG_AgilityUseCases_Whitepaper-FINAL.pdf, accessed: 2024-07-04.
- [10] ETSI, “CYBER; Migration strategies and recommendations to Quantum Safe schemes,” ETSI Technical Committee Cyber Security (CYBER), Tech. Rep. ETSI TR 103 619, July 2020.
- [11] D. Sikeridis, D. Ott, S. Huntley, S. Sharma, V. Dhanasekar, M. Bansal, A. Kumar, A. N. D. Beveridge, and S. Veeraswamy, “ELCA: Introducing Enterprise-level Cryptographic Agility for a Post-Quantum Era,” Cryptology ePrint Archive, Paper 2023/1539, 2023.
- [12] W. Barker, W. Polk, and M. Souppaya, “Getting Ready for Post-Quantum Cryptography,” National Institute of Standards and Technology, Tech. Rep., 2021.
- [13] R. Housley, “Guidelines for Cryptographic Algorithm Agility and Selecting Mandatory-to-Implement Algorithms,” RFC 7696, nov 2015.
- [14] D. Ott, C. Peikert, and et al., “Identifying Research Challenges in Post Quantum Cryptography Migration and Cryptographic Agility,” *CoRR*, vol. abs/1909.07353, 2019.
- [15] J. Fan, F. Willems, J. Zahed, J. Gray, S. Mister, M. Ounsworth, and C. Adams, “Impact of post-quantum hybrid certificates on PKI, common libraries, and protocols,” *International Journal of Security and Networks*, vol. 16, no. 3, pp. 200–211, 2021.
- [16] V. Vasić, M. Mikuc, and M. Vuković, “Lightweight and adaptable solution for security agility,” *KSII Transactions on Internet and Information Systems*, vol. 10, no. 3, pp. 1212–1228, March 2016.
- [17] L. Zhang, A. Miranskyy, W. Rjaibi, G. Stager, M. Gray, and J. Peck, “Making existing software quantum safe: A case study on IBM Db2,” *Information and Software Technology*, vol. 161, p. 107249, Sep. 2023.
- [18] ISARA Corporation, “Managing Cryptographic and Quantum Risk,” 2020, accessed: 2024-07-04. [Online]. Available: <https://www.isara.com/resource-center/managing-cryptographic-and-quantum-risk.html>
- [19] A. Wiesmaier, N. Alnahawi, T. Grasmeyer, J. Geißler, A. Zeier, P. Bauspieß, and A. Heinemann, “On PQC Migration and Crypto-Agility,” 2021.
- [20] S. Paul and M. Niethammer, “On the importance of cryptographic agility for industrial automation,” *at - Automatisierungstechnik*, vol. 67, no. 5, pp. 402–416, 2019.
- [21] N. Alnahawi, N. Schmitt, A. Wiesmaier, A. Heinemann, and T. Grasmeyer, “On the State of Crypto-Agility,” Cryptology ePrint Archive, Paper 2023/487, 2023.
- [22] S. Paul, “On the Transition to PostQuantum Cryptography in the Industrial Internet of Things,” Ph.D. dissertation, Technische Universität Darmstadt, 2021.
- [23] I. Würth and M. Zanetti, “Post Quantum Cryptography,” 2021, accessed: 2024-07-04. [Online]. Available: <https://eprints.ost.ch/id/eprint/1012>
- [24] R. Cunningham, L. Parker, F. Schenker, and E. Wrubel, “Post-Quantum Cryptography and Implications for System Acquisition,” CARNEGIE-MELLON UNIV PITTSBURGH PA, Tech. Rep., 2021, accessed: 2024-07-04.
- [25] DigiCert Inc., “Post-Quantum Cryptography (PQC) Maturity Model,” Whitepaper, 2020, accessed: 2024-07-04. [Online]. Available: <https://www.digicert.com/content/dam/digicert/pdfs/post-quantum-cryptography-maturity-model-whitepaper-en.pdf>
- [26] E. Heftrig, H. Shulman, and M. Waidner, “Poster: The Unintended Consequences of Algorithm Agility in DNSSEC,” in *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security*, ser. CCS ’22. New York, NY, USA: Association for Computing Machinery, 2022, p. 3363–3365.
- [27] V. Vasic and M. Mikuc, “Security Agility Solution Independent of the Underlying Protocol Architecture,” 2012. [Online]. Available: <https://eur-ws.org/Vol-918/11110128.pdf>

- [28] B. Sullivan, “Security Briefs - Cryptographic Agility,” MSDN Magazine Issues Volume 24 Number 08, 2009, accessed: 2024-07-04. [Online]. Available: <https://learn.microsoft.com/en-us/archive/msdn-magazine/2009/august/cryptographic-agility>
- [29] B. LaMacchia, “The long road ahead to transition to post-quantum cryptography,” *Commun. ACM*, vol. 65, no. 1, p. 28–30, dec 2021.
- [30] A. Mashatan and D. Heintzman, “The Complex Path to Quantum Resistance: Is your organization prepared?” *Queue*, vol. 19, no. 2, p. 65–92, may 2021.
- [31] H. Mehrez and O. Omri, “The Crypto-Agility Properties,” in *Proceedings of The 12th International Multi-Conference on Society, Cybernetics and Informatics (IMSCI)*, N. e. a. Callaos, Ed. International Institute of Informatics and Systemics (IIS), 2018.
- [32] T. Attema, J. Duarte, V. Dunning, M. Lequesne, W. van der Schoot, and M. Stevens, “The PQC Migration Handbook GUIDELINES FOR MIGRATING TO POST-QUANTUM CRYPTOGRAPHY,” TNO - Applied Cryptography and Quantum Algorithms and CWI - Cryptology Group and AIVD - Netherlands National Communications Security Agency, Tech. Rep., March 2023, accessed Feb. 12, 2024. [Online]. Available: <https://www.tno.nl/en/newsroom/2023/04-0/pqc-migration-handbook/>
- [33] J. Hohm, A. Heinemann, and A. Wiesmaier, “Towards a maturity model for crypto-agility assessment,” in *Foundations and Practice of Security*, G.-V. Jourdan, L. Mounier, C. Adams, F. Sèdes, and J. Garcia-Alfaro, Eds. Cham: Springer Nature Switzerland, 2023, pp. 104–119.
- [34] S. Yunakovsky, M. Kot, N. Pozhar, D. Nabokov, M. Kudinov, A. Guglya, E. Kiktenko, E. Kolycheva, A. Borisov, and A. Fedorov, “Towards security recommendations for public-key infrastructures for production environments in the post-quantum era,” *EPJ Quantum Technology*, vol. 8, no. 1, p. 14, May 2021.
- [35] K. Heid, J. Heider, M. Ritscher, and J.-P. Stotz, “Tracing Cryptographic Agility in Android and iOS Apps,” in *Proceedings of the 9th International Conference on Information Systems Security and Privacy - Volume 1: ICISSP, INSTICC*. SciTePress, 2023, pp. 38–45.
- [36] J. Henry, “WHAT IS CRYPTO-AGILITY?” 2018, accessed: 2024-07-04. [Online]. Available: <https://www.cryptomathic.com/news-events/blog/what-is-crypto-agility>
- [37] D. Ott, K. Paterson, and D. Moreau, “Where Is the Research on Cryptographic Transition and Agility?” *Commun. ACM*, vol. 66, no. 4, p. 29–32, mar 2023.
- [38] L. Marchesi, M. Marchesi, and R. Tonelli, “A survey on cryptoagility and agile practices in the light of quantum resistance,” *Information and Software Technology*, vol. 178, p. 107604, 2025.
- [39] J. Cho, C. Lee, E. Kim, J. Lee, and B. Cho, “Software-defined cryptography: A design feature of cryptographic agility,” 2024.
- [40] A. Silonosov and L. Henesey, “Towards cryptographic agility manifesto in end-to-end encryption systems: a position paper from the perspective of crypto-consumers,” in *2024 IEEE Conference on Dependable, Autonomic and Secure Computing (DASC)*, 2024, pp. 65–72.
- [41] M. Alqabandi, “Introducing cryptographic agility in mobile banking,” Ph.D. dissertation, University of Amsterdam, 02 2024.
- [42] A. Ras, A. Loiseau, M. Carmona, S. Pontié, G. Renault, B. Smith, and E. Valea, “PHOENIX: Crypto-agile hardware sharing for ML-KEM and HQC,” *Cryptology ePrint Archive*, Paper 2025/601, 2025.
- [43] T. Frauenschläger and J. Mottok, “Problems and New Approaches for Crypto-Agility in Operational Technology,” in *12th European Congress Embedded Real Time Systems - ERTS 2024*, Toulouse, France, 06 2024.
- [44] S. Fries and R. Falk, “Supporting cryptographic algorithm agility with attribute certificates,” *International Journal On Advances in Security*, vol. 17, no. 1-2, pp. 92–98, 06 2024.
- [45] M. Galambos, Á. Vázquez-Castro, and L. Bacsárdi, “Hardware supported crypto-agility in quantum key distribution and physical layer security,” in *2025 IEEE 19th International Symposium on Applied Computational Intelligence and Informatics (SACI)*, 2025, pp. 000 069–000 074.
- [46] S. P. Sanon and H. D. Schotten, “Quantum-ready mobile communications: Cryptographic agility for mobile networks in the quantum era,” in *2025 IEEE 26th International Symposium on a World of Wireless, Mobile and Multimedia Networks (WoWMoM)*, 2025, pp. 287–292.
- [47] M.-A. Kourtis, G. Oikonomakis, I. Koufos, G. Xilouris, I. Kefaloukos, E. Markakis, D. Karcz, and M. Niemiec, “Adaptive post-quantum cryptography for blockchain: Enhancing security and energy efficiency with cryptographic agility,” in *2025 6th International Conference in Electronic Engineering & Information Technology (EEITE)*, 2025, pp. 1–5.
- [48] E. Barker, L. Chen, D. Cooper, D. Moody, A. Regenscheid, M. Souppaya, W. Newhouse, R. Housley, S. Turner, W. Barker, and K. Scarfone, “Considerations for achieving cryptographic agility: Strategies and practices,” NIST, Computer Security Resource Center, CSWP (Cybersecurity White Paper) 39, 2nd Public Draft, 07 2025.

REFERENCES

- [49] W. Stallings, *Cryptography and Network Security: Principles and Practice, Global Ed*, 8th ed. Pearson, 2022.
- [50] R. Zhang, R. Xue, and L. Liu, “Security and Privacy on Blockchain,” *ACM Comput. Surv.*, vol. 52, no. 3, jul 2019.
- [51] G. C. Kessler, “An overview of cryptography,” 2019, updated Version 24 January 2019. [Online]. Available:

- <https://commons.erau.edu/publication/412/>
- [52] F. Wilhelm, R. Steinwandt, D. Zeuch, and J. Frey, "Status of quantum computer development," Federal office for Information Security, Tech. Rep., 2023. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Studien/Quantencomputer/Entwicklungsstand_QC_V_2_0.pdf
 - [53] L. Chen, S. Jordan, Y.-K. Liu, D. Moody, R. Peralta, R. Perlner, and D. Smith-Tone, "Report on Post-Quantum Cryptography," 2016.
 - [54] Stephan Ehlen and Heike Hagemeyer and Tobias Hemmert and Stavros Kousidis and Manfred Lochter and Stephanie Reinhardt and Thomas Wunderer, "Kryptographie quantensicher gestalten," Federal Office for Information Security (BSI), Tech. Rep., 2021.
 - [55] D. Bernstein and T. Lange, "Post-quantum cryptography," *Nature*, vol. 549, no. 7671, pp. 188–194, 2017.
 - [56] R. Niederhagen and M. Waidner, "Practical post-quantum cryptography," *Fraunhofer SIT*, 2017.
 - [57] M. Randolph and W. Diehl, "Power Side-Channel Attack Analysis: A Review of 20 Years of Study for the Layman," *Cryptography*, vol. 4, no. 2, 2020.
 - [58] J. Dooley, *History of Cryptography and Cryptanalysis*, 1st ed. Springer Cham, 2018.
 - [59] K. Moriarty and S. Farrell, "Deprecating TLS 1.0 and TLS 1.1," RFC 8996, Mar. 2021. [Online]. Available: <https://www.rfc-editor.org/info/rfc8996>
 - [60] J. B. Jr., "National Security Memorandum on Promoting United States Leadership in Quantum Computing While Mitigating Risks to Vulnerable Cryptographic Systems (NSM-10)," The White House, Tech. Rep., May 2022. [Online]. Available: <https://www.whitehouse.gov/briefing-room/statements-releases/2022/05/04/national-security-memorandum-on-promoting-united-states-leadership-in-quantum-computing-while-mitigating-risks-to-vulnerable-cryptographic-systems/>
 - [61] Federal Office for Information Security (BSI), "Kryptographische Verfahren: Empfehlungen und Schlüssellängen," Federal Office for Information Security (BSI), Bonn, DE, Technical Guideline BSI TR-02102-1, February 2024.
 - [62] —, "Migration zu Post-Quanten-Kryptografie," Federal Office for Information Security (BSI), Bonn, DE, Technical Guideline, August 2020. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Krypto/Post-Quanten-Kryptografie.pdf?__blob=publicationFile&v=1
 - [63] Lily Chen. (2024) Crypto-Transition and Agility. National Institute of Standards and Technology (NIST). [Online]. Available: https://csrc.nist.gov/csrc/media/Presentations/2024/cryptographic-agility-and-transition-read-and-plans/Chen-Day2-Crypto-Agility_and%2BTransition_R_and_D_Plans.pdf
 - [64] National Institute of Standards and Technology (NIST), "Digital Signature Standard (DSS)," May 1994.
 - [65] —, "Digital Signature Standard (DSS)," Feb. 2023.
 - [66] D. Johnson and A. Menezes, "Elliptic curve DSA (ECDSA): an enhanced DSA," in *Proceedings of the 7th conference on USENIX Security Symposium*, vol. 7, 1998, pp. 13–23.
 - [67] J. Stapleton, R. Poore, and P. Bordow, "Cryptographic transitions: Historical considerations," *ISAA Journal*, vol. 20, pp. 16–24, Sep 2022.
 - [68] R. van Rijswijk-Deij, M. Jonker, and A. Sperotto, "On the adoption of the elliptic curve digital signature algorithm (ECDSA) in DNSSEC," in *2016 12th International Conference on Network and Service Management (CNSM)*, 2016, pp. 258–262.
 - [69] J. Sowa, B. Hoang, A. Yeluru, S. Qie, A. Nikolic, R. Iyer, and P. Cao, "Post-Quantum Cryptography (PQC) Network Instrument: Measuring PQC Adoption Rates and Identifying Migration Pathways," 2024.
 - [70] National Institute of Standards and Technology (NIST), "NIST FIPS Publications," 2024, accessed: 2024-10-09. [Online]. Available: <https://csrc.nist.gov/publications/fips>
 - [71] V. Arutyunov, "Clustering of information-security standards of the Russian Federation," *Scientific and technical information processing*, vol. 44, pp. 125–133, 2017.
 - [72] J. Stapleton and R. Poore, "Cryptographic transitions," in *2006 IEEE Region 5 Conference*, 2006, pp. 22–30.
 - [73] D. Bernstein, T. Lange, C. Chuengsatiansu, and C. van Vredendaal, "NTRU Prime," *NIST submissions*, 2017.
 - [74] M. Braithwaite, "Experimenting with Post-Quantum Cryptography," <https://security.googleblog.com/2016/07/experimenting-with-post-quantum.html>, Jul. 2016, accessed: 2024-10-08.
 - [75] K. Kwiatkowski and L. Valenta, "The TLS Post-Quantum Experiment," <https://blog.cloudflare.com/the-tls-post-quantum-experiment/>, Oct. 2019, accessed: 2024-10-08.
 - [76] V. Smyslov, "Intermediate Exchange in the Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 9242, May 2022.
 - [77] C. Tjhai, M. Tomlinson, G. Bartlett, S. Fluhrer, D. van Geest, O. Garcia-Morchon, and V. Smyslov, "Multiple Key Exchanges in the Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 9370, May 2023.
 - [78] C. Tjhai, T. Heider, and V. Smyslov, "Beyond 64KB Limit of IKEv2 Payloads," Internet Engineering Task Force, Internet-Draft draft-tjhai-ikev2-beyond-64k-limit-03, Jul. 2022, work in Progress.
 - [79] Y. Nir, "A Larger Internet Key Exchange version 2 (IKEv2) Payload," Internet Engineering Task Force, Internet-Draft draft-nir-ipsecme-big-payload-04, Sep. 2024, work in Progress.
 - [80] C. Kaufman, P. Hoffman, Y. Nir, P. Eronen, and T. Kivinen, "Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 7296, Oct. 2014.
 - [81] S. Fluhrer, P. Kampanakis, D. McGrew, and V. Smyslov, "Mixing Preshared Keys in the Internet Key Exchange Protocol Version 2 (IKEv2) for Post-quantum Security,"

- RFC 8784, Jun. 2020.
- [82] D. Herzinger, S.-L. Gazdag, and D. Loebenberger, “Real-World Quantum-Resistant IPsec,” in *2021 14th International Conference on Security of Information and Networks (SIN)*, vol. 1, 2021, pp. 1–8.
- [83] M. Page, J. McKenzie, P. Bossuyt, I. Boutron, T. Hoffmann, C. Mulrow, L. Shamseer, J. Tetzlaff, E. Akl, S. Brennan, R. Chou, J. Glanville, J. Grimshaw, A. Hróbjartsson, M. Lalu, T. Li, E. Loder, E. Mayo-Wilson, S. McDonald, L. McGuinness, L. Stewart, J. Thomas, A. Tricco, V. Welch, P. Whiting, and D. Moher, “The PRISMA 2020 statement: an updated guideline for reporting systematic reviews,” *Systematic Reviews*, vol. 10, no. 1, p. 89, Mar. 2021.
- [84] A. Paez, “Gray literature: An important resource in systematic reviews,” *Journal of Evidence-Based Medicine*, vol. 10, no. 3, pp. 233–240, 2017.
- [85] C. Näther, “Replication Package: Toward a Common Understanding of Cryptographic Agility – A Systematic Review,” 2025. [Online]. Available: <https://iee-dataport.org/documents/replication-package-toward-common-understanding-cryptographic-agility-systematic-review>
- [86] F. D. M. P. and B. Hale, “Terminology for Post-Quantum Traditional Hybrid Schemes,” Internet Engineering Task Force, Internet-Draft draft-ietf-pquip-pqt-hybrid-terminology-04, Sep. 2024, work in Progress.
- [87] A. Majot and R. Yampolskiy, “Global catastrophic risk and security implications of quantum computers,” *Futures*, vol. 72, pp. 17–26, 2015, confronting Future Catastrophic Threats To Humanity.
- [88] M. Müller, W. Toorop, T. Chung, J. Jansen, and R. van Rijswijk-Deij, “The Reality of Algorithm Agility: Studying the DNSSEC Algorithm Life-Cycle,” in *Proceedings of the ACM Internet Measurement Conference*, ser. IMC ’20. New York, NY, USA: Association for Computing Machinery, 2020, p. 295–308.
- [89] E. Alashwali and K. Rasmussen, “What’s in a Downgrade? A Taxonomy of Downgrade Attacks in the TLS Protocol and Application Protocols Using TLS,” *CoRR*, vol. abs/1809.05681, 2018.
- [90] S. Lee, Y. Shin, and J. Hur, “Return of version downgrade attack in the era of TLS 1.3,” in *Proceedings of the 16th International Conference on Emerging Networking EXperiments and Technologies*, ser. CoNEXT ’20. New York, NY, USA: Association for Computing Machinery, 2020, p. 157–168.
- [91] A. Viand, P. Jattke, and A. Hithnawi, “SoK: Fully Homomorphic Encryption Compilers,” in *2021 IEEE Symposium on Security and Privacy (SP)*, 2021, pp. 1092–1108.
- [92] H. Ahmed, S. Zubair, and M. Tawfik, “A privacy-preserving cloud storage framework with hybrid encryption, homomorphic keyword search, and blockchain-based integrity verification,” *Scientific Reports*, 2026.
- [93] C. Näther, D. Herzinger, S.-L. Gazdag, J.-P. Steghöfer, S. Daum, and D. Loebenberger, “Migrating software systems toward post-quantum cryptography-a systematic literature review,” *IEEE Access*, vol. 12, pp. 132 107–132 126, 2024.
- [94] A. Ampatzoglou, S. Bibi, P. Avgeriou, and A. Chatzigeorgiou, *Guidelines for Managing Threats to Validity of Secondary Studies in Software Engineering*. Cham: Springer International Publishing, 2020, pp. 415–441.



member of XITASO's information security community, where he promotes both internal and customer-specific security.

CHRISTIAN NÄTHER received his Master's degree in Computer Science from the University of Augsburg, Germany. As a former software engineer, he has gained several years of experience in the fields of software development, distributed systems as well as information security. He is currently a security researcher at XITASO and part of the research project AMiQuaSy, which focuses on the migration of systems towards post-quantum cryptography. Christian Näther is an active board



PQC RFC, RFC 8391 describing the signature scheme XMSS, recommended e.g. by US NIST, NSA and German BSI.

STEFAN-LUKAS GATZDAG holds a Master of Science in Computer Science. He has focused on post-quantum cryptography (PQC) and future-proof security mechanisms since 2013, overcoming obstacles in practical use. Being part of the German IT security company genua's research group he currently works on the fourth publicly funded PQC research project and other collaborations, enabling the transition to quantum-safe networks. He was e.g. involved in the publication of the first explicit



passion for PQC by joining the research group in 2023, focusing on the transition of complex systems and infrastructures to quantum resistance.

DANIEL HERZINGER holds a Master of Science in Computer Science. He started working on post-quantum cryptography (PQC) and its adoption into real-world scenarios during his Master's thesis in 2020, together with the German IT security company genua, where he started his IT security journey in 2015. After finishing his studies, he first dived into supporting customers with securing their IT and OT infrastructures at genua's consulting department for two years. He then indulged in his



research interests span software engineering, industrial automation, big data engineering as well as security. He is currently a researcher at the Technical University Amberg-Weiden, where he focuses on advancing both practical and theoretical aspects of PQC migration but also teaches in the area of security.

EDUARD HIRSCH holds a Master of Science degree in Computer Science from the Technical University of Vienna. Over the years he accumulated extensive experience in industry, contributing to various projects in the software and technology sector. In addition to his professional work, he has been teaching and doing research at the Salzburg University of Applied Sciences, where he was contributing to national (Austria) and international research projects (e.g. H2020, Interreg). His re-



as an active member of the software engineering community where he is part of the organisation committee for events like the IEEE International Requirements Engineering Conference (RE). He also reviews for International Conference on Software Engineering (ICSE), IEEE Transactions on Software Engineering (TSE), Journal of Systems and Software (JSS), Empirical Software Engineering and Measurement (ESEM), and many other venues.

JAN-PHILIPP STEGHÖFER (Member, IEEE) received the Ph.D. degree in Computer Science from the University of Augsburg, Germany. As a former professor at the University of Gothenburg he has an extensive and distinguished academic background with a strong passion for research and innovation. His research interests include security assurance, security of AI systems, agile development in regulated domains, and model-driven engineering. He is currently Head of Research at XITASO as well



of Cybersecurity at the Technical University Amberg-Weiden and also heads the department "Secure Infrastructure" at Fraunhofer AISEC's Weiden site. In the lab there, topics of applied post-quantum cryptography and quantum-safe infrastructures are addressed in research and teaching.

DANIEL LOEBENBERGER received his doctorate in cryptography from the University of Bonn in 2012, where he conducted research and taught until the end of 2015. From 2016 to 2019, he worked as an IT security expert with a focus on cryptography at genua GmbH, a subsidiary of the Bundesdruckerei GmbH, the German Federal Printing Office, on various topics of professional high-security components. Since January 2019, Daniel Loebenberg has been appointed Professor

...